IAPP Hungary KnowledgeNet Chapter | 2026. 04. 28.

Rise of the Naive Machine

What Are the Security Weaknesses of LLMs and Agents?

12+ years in software security

Market leading SaaS companies

MSc in Machine Learning / Data Analytics

ISO 27001, ISO 42001, CISSP, OSCP, eMBA

Jozsef Ottucsak (@fuzboxz)

Staff Product Security Architect
Diligent Inc.

Topics

Basic technical primer on AI

Inherent limitations of AI

Common AI systems and their risks

Large Language Model Basics - I

Fundamentals

LLMs **predict text** using mathematical patterns learned from massive datasets and fine-tuning. Base models already contain large amounts of security knowledge from public resources.

Reasoning

Some models generate internal chain of thought text to come up with better outputs. These are called thinking or reasoning models. **Reasoning blocks are often hidden** from the user.

Tool Use

LLMs produce **tool call** syntax that the **host** processes and **runs**. Results are then fed back into the LLM for processing and output.

Large Language Model Basics - II

Multimodal Models

Encodes images or sound into **mathematical representation** understandable for machines. Transforms data to a **shared format** so that it can process information in multimodal content just like it text.

RAG

For search the LLMs are often deployed so that they try to **retrieve information first** and based on the result **respond in a natural text**. Eg. *Fact + Explanation*

Pricing

Usually based on **input tokens AND output tokens**, the more data you process the more you will pay.

Pricing does **include thinking** which is hidden from the user.

Large Language Model Basics - III

Local Inference

Hosting models **requires a lot of RAM and advanced GPUs**. Edge computation possible, but not as good as large models.

Enterprise grade setup requires 15-65+ million HUF investment and redundancy.

Guardrails

Generic term for **LLM safety measures**, most models have some kind of safety guardrails built-in. Can be simple to advanced.

Often separate models are used only as guardrails, which raises the cost of inference.

Agents

LLMs with **tool access** capable of acting **autonomously** to complete a **goal**. Agent harness manages the agent lifecycle, goals and restrictions.

Observe-Orient-Decide-Act

LLM and Agentic Risks

Prompt injection, goal hijacking

Models can't differentiate between data and instructions. Well-structured inputs, role playing might convince a model to take malicious actions. Any data or user input might contain malicious instructions.

Excessive Agency

Unrestricted agents may take any action to achieve goals - even if they shouldn't. If an agent has access to something, expect that there is or will be a way for it to abuse that.

Hallucination and cascading failure

Probabilistic output generation might drift model/agents towards generating incorrect output, taking unexpected or even malicious actions. Prompts may accumulate over multiple agents and inference rounds.

Bias, backdoors and supply chain

Training, inputs and data might bias models towards taking specific decisions. There could be hidden keywords that trigger unexpected behavior in the LLM. Coding agents could pull vulnerable or compromised packages.

Current AI Systems in Enterprise

Operating system level AI functionality 💻

- Lightweight edge AI functions baked into the operating system
- May include: runtime, text or image processing, transcription, etc.

Agentic host 🔃

- Interface between user, LLM and data sources (local or hosted)
- Can be web based, desktop application or terminal UI
- Copilot, Glean, Claude Desktop
- Can take actions (search, use computer, etc) through runtime and integrations
- Interface with external systems through MCP servers
    - Any system supporting MCP "standard"

SaaS with built-in LLM/agentic workflows 🧩

- Applications started including AI based features
- Specific, limited scope AI functionality bolted-on existing systems

Key Risks in AI Business Systems

- Identity - *Legacy user based identity*
- Access Control - *Access is often poorly limited*
- Data Segmentation - *How to segment access between different stakeholders*
- Data Quality - *Poor quality data leads to confusion and unexpected behavior*
- Data Sovereignty - *AI workloads are limited by compute -> global inference*
- Shadow AI - *Use of unapproved AI tools AND in-house AI built tooling*
- Privacy - *AI systems need excessive telemetry*
- Costs - *AI is expensive, costs are rising, no clear ROI defined*

Questions

Thank you!